CRISC Exam - Hard Questions with Explanations

From Open Source CRISC Exam Guide

Compiled from GTPs and AI

October 25, 2026

Outline

1. Domain 1: Governance
2. Domain 1: Legal and Ethics
3. Domain 2: Risk Management Life Cycle
4. Domain 2: Threat, Vulnerability, Risk
5. Domain 2: Risk Assessment Frameworks
6. Domain 2: Business Impact Analysis
7. Domain 3: Risk Response
8. Domain 3: Third-Party Risk Management
9. Domain 3: Control Design
10. Domain 3: Monitoring and Reporting
11. Domain 4: Enterprise Architecture
12. Domain 4: Data Life Cycle
13. Domain 4: SDLC
14. Domain 4: Information Security

Q1: Governance Accountability

Question

Which is the PRIMARY objective of an organizational governance structure?

- A Monitor the effectiveness of operational controls
- B Establish accountability and direction for achieving enterprise objectives
- C Manage business processes and operational risks
- D Implement risk response activities across the enterprise

Q1: Explanation

Correct Answer: B

Governance provides direction, oversight, and accountability to ensure enterprise objectives are achieved and aligned with stakeholder expectations.

Option Analysis

- **A - Incorrect:** Monitoring controls is primarily a management function.
- **B - Correct:** Governance establishes accountability, oversight, and strategic alignment.
- **C - Incorrect:** Managing processes and risks is an operational responsibility.
- **D - Incorrect:** Risk response implementation is performed by management.

Q1: Governance Versus Management

Question

Senior leadership wants to ensure risk management activities support organizational objectives and stakeholder expectations. Which is MOST important?

- A Defining operational procedures
- B Establishing governance and accountability structures
- C Performing periodic risk assessments
- D Implementing compensating controls

Q1: Correct Answer

Answer: B

Governance provides direction, oversight, and accountability to ensure that risk management activities support business objectives and stakeholder expectations.

Q1: Option Analysis

A - Defining Operational Procedures (Incorrect)

- Operational procedures describe how work is performed.
- This is a management responsibility.
- Procedures help execute strategy but do not establish enterprise accountability.

B - Establishing Governance and Accountability Structures (Correct)

- Governance aligns risk management with business objectives.
- Establishes accountability and oversight.
- Ensures stakeholder expectations are addressed.
- Provides direction for management activities.

Q1: Option Analysis (Continued)

C - Performing Periodic Risk Assessments (Incorrect)

- Risk assessments identify and evaluate risks.
- They are important management activities.
- However, governance must be established before risk assessments can effectively support enterprise objectives.

D - Implementing Compensating Controls (Incorrect)

- Compensating controls reduce risk when primary controls are unavailable or insufficient.
- Control implementation is a management responsibility.
- Controls support governance but do not replace it.

Q1: Exam Trap

Common CRISC Trap

Risk assessments and controls sound risk-focused and are often selected by candidates. However, the question emphasizes:

- Senior leadership
- Organizational objectives
- Stakeholder expectations

These are governance concepts, making governance and accountability structures the BEST answer.

Q1: Governance vs Management

Remember

Governance

- Provides direction
- Establishes accountability
- Aligns with stakeholder expectations
- Oversees performance

Management

- Implements controls
- Performs risk assessments
- Executes procedures
- Runs day-to-day operations

Q1: Summary Question

Remember for the Exam

Which activity provides the foundation that ensures risk management supports enterprise objectives?

1. Operational Procedures
2. Governance and Accountability Structures **(Correct)**
3. Risk Assessments
4. Compensating Controls

Governance comes before management activities.

Q2: Risk Management First Step

Question

Which of the following is the first step in IT risk management?

A. IT risk assessment
B. Risk response and mitigation
C. IT risk identification
D. Risk reporting

Q2: Explanation

Correct Answer: C

IT risk identification is the first step of IT risk management. You cannot protect what you do not know exists.

Option Analysis

- **A - Incorrect:** Assessment comes after identification
- **B - Incorrect:** Response comes after assessment
- **C - Correct:** Identification is the first step
- **D - Incorrect:** Reporting is the final step

Q3: Oversight Responsibility

Question

Oversight and direction are the responsibility of who?

- A Management
- B Senior staff
- C IT risk manager
- D Board of directors

Q3: Explanation

Correct Answer: D

Oversight and direction are the responsibility of the board of directors.

Option Analysis

- **A - Incorrect:** Management executes, doesn't provide oversight
- **B - Incorrect:** Senior staff don't provide governance oversight
- **C - Incorrect:** Risk manager executes risk activities
- **D - Correct:** Board provides oversight and direction

Q4: Policy Documentation Hierarchy

Question

The high-level intent of an organization's security practices is best established by which of the following?

A. Procedures
B. Policies
C. Guidelines
D. Processes

Q4: Explanation

Correct Answer: B

Policies are the high-level intent of organizations for security practices.

Option Analysis

- **A - Incorrect:** Procedures are detailed steps
- **B - Correct:** Policies express management intent
- **C - Incorrect:** Guidelines are recommendations
- **D - Incorrect:** Processes are operational

Q5: RACI Model

Question

Which group should be reached out to for expert guidance on the working group?

A. Responsible
B. Accountable
C. Consulted
D. Informed

Q5: Explanation

Correct Answer: C

Consulted working groups are the subject matter experts for guidance on initiatives in their domain of expertise.

Option Analysis

- **A - Incorrect:** Responsible does the work
- **B - Incorrect:** Accountable provides resources
- **C - Correct:** Consulted are subject matter experts
- **D - Incorrect:** Informed are kept updated

Q6: Risk Culture Focus

Question

An IT risk manager recently joined an organization with past security incidents. What should be the primary focus in the first few months?

A. Cite individuals who caused incidents

B. Understand the organization's culture toward risk

C. Draft strategy for IT risk management

D. Complete all security awareness training

Q6: Explanation

Correct Answer: B

The risk manager needs to understand the culture of the organization before drafting strategy.

Option Analysis

- **A - Incorrect:** Blaming individuals is counterproductive
- **B - Correct:** Culture understanding is foundational
- **C - Incorrect:** Strategy comes after understanding culture
- **D - Incorrect:** Training is secondary to culture assessment

Q8: Third LoD Responsibility

Question

What is the primary responsibility of the third LoD?

A. Policy and procedure development
B. Provide independent assurance of controls
C. Perform periodic user reviews
D. Restrict least privileged roles

Q8: Explanation

Correct Answer: B

The third LoD is primarily responsible for independent assurance of controls through internal/external audit.

Option Analysis

- **A - Incorrect:** Policy development is second LoD
- **B - Correct:** Independence is key for third LoD
- **C - Incorrect:** User reviews are operational (first LoD)
- **D - Incorrect:** Access control is operational

Q11: Risk Tolerance vs Capacity

Question

Which statement is correct?

A. Breaching risk tolerance threatens existence

B. Breaching risk capacity threatens existence

C. Risk tolerance and capacity are not related

D. Risk tolerance and capacity are the same

Q11: Explanation

Correct Answer: B

Breaching risk capacity could threaten an organization's existence.

Option Analysis

- **A - Incorrect:** Tolerance breach is manageable
- **B - Correct:** Capacity breach threatens existence
- **C - Incorrect:** They are related
- **D - Incorrect:** They are different concepts

Q12: HIPAA

Question

Which federal law provides guidance on protecting sensitive health information?

A. CCPA
B. HIPAA
C. FFIEC
D. GDPR

Q12: Explanation

Correct Answer: B

HIPAA is the federal law protecting sensitive health information.

Option Analysis

- **A - Incorrect:** CCPA is California privacy law
- **B - Correct:** HIPAA is health information law
- **C - Incorrect:** FFIEC is banking regulation
- **D - Incorrect:** GDPR is EU regulation

Q13: CCPA Beneficiaries

Question

Which group is a beneficiary of CCPA law?

A. US residents
B. EU residents
C. California residents
D. Canada residents

Q13: Explanation

Correct Answer: C

CCPA protects California residents' personal information.

Option Analysis

- **A - Incorrect:** US residents is too broad
- **B - Incorrect:** EU residents are covered by GDPR
- **C - Correct:** California residents
- **D - Incorrect:** Canada residents have PIPEDA

Q17: Risk Identification Principle

Question

Which risk management life cycle step emphasizes "You can't protect what you don't know exists"?

A. Risk and control monitoring
B. Risk assessment
C. Risk identification
D. Risk categorization

Q17: Explanation

Correct Answer: C

Risk identification is the first step - you must know risks exist.

Option Analysis

- **A - Incorrect:** Monitoring happens after identification
- **B - Incorrect:** Assessment comes after identification
- **C - Correct:** Identification discovers risks
- **D - Incorrect:** Categorization comes after identification

Q18: Formal Risk Assessment Requirement

Question

Which is a formal requirement by many legal and regulatory compliance frameworks?

A. Performing vulnerability assessments
B. Maintaining asset inventory
C. Deploying changes without testing
D. Conducting formal risk assessment

Q18: Explanation

Correct Answer: D

Conducting formal risk assessment is a requirement of many legal and regulatory compliance frameworks.

Option Analysis

- **A - Incorrect:** Vulnerability assessments are important but not universally mandatory
- **B - Incorrect:** Asset inventory is good practice but not always required
- **C - Incorrect:** This is poor practice
- **D - Correct:** Formal risk assessment is widely mandated

Q19: Event vs Incident vs Breach

Question

A healthcare employee accidentally sent more than 5,000 patient records in response to a phishing email. This is a:

- A Issue
- B Event
- C Incident
- D Breach

Q19: Explanation

Correct Answer: D

This is a breach - unauthorized disclosure of PHI affecting more than 500 individuals.

Option Analysis

- **A - Incorrect:** Issue is a condition, not an occurrence
- **B - Incorrect:** Event alone doesn't cause negative outcome
- **C - Incorrect:** Incident is one or more events with negative outcome
- **D - Correct:** Breach is unauthorized disclosure

Q22: CXXX

Question

Which scoring technique is used to quantify a vulnerability?

- A CSS
- B CSV
- C CVSS
- D CVVS

Q22: Explanation

Correct Answer: C

Common Vulnerability Scoring System (CVSS) is used to quantify vulnerabilities.

Option Analysis

- **A - Incorrect:** CSS is not vulnerability scoring
- **B - Incorrect:** CSV is file format
- **C - Correct:** CVSS is the standard
- **D - Incorrect:** CVVS is not standard

Q22: Vulnerability Risk Assessment

Question

An organization uses CVSS scores to prioritize vulnerability remediation. A vulnerability with a CVSS score of 9.8 affects a low-value internal system, while a vulnerability with a CVSS score of 6.5 affects a customer-facing payment application. What should the risk professional do FIRST?

A. Remediate the 9.8 vulnerability immediately because it has the highest score.

B. Escalate both vulnerabilities directly to the board.

C. Assess business impact and threat context before prioritizing remediation.

D. Accept the 6.5 vulnerability because it is below 7.0.

Q22: Explanation

Correct Answer: C

CVSS measures technical severity, not business risk. Risk decisions should consider asset criticality, business impact, threat landscape, and organizational risk appetite in addition to CVSS scores.

Option Analysis

- **A - Incorrect:** Highest CVSS does not automatically mean highest business risk.
- **B - Incorrect:** Board escalation is not the first step.
- **C - Correct:** Business context must be evaluated before remediation priorities are established.
- **D - Incorrect:** Risk acceptance cannot be based solely on CVSS thresholds.

Q23: Quantitative Risk Framework

Question

Which framework is primarily used for quantitative risk management?

A. NIST 800-30
B. FAIR
C. ISO 27001
D. ISO 27005

Q23: Explanation

Correct Answer: B

FAIR (Factor Analysis of Information Risk) is primarily used for quantitative risk management.

Option Analysis

- **A - Incorrect:** NIST 800-30 is qualitative
- **B - Correct:** FAIR is quantitative
- **C - Incorrect:** ISO 27001 is management standard
- **D - Incorrect:** ISO 27005 is qualitative

Q23: Selecting a Risk Analysis Method

Question

Senior management wants to compare the potential annual financial impact of ransomware risk against the cost of implementing additional security controls. Which approach would BEST support this analysis?

A. Use FAIR to estimate probable loss exposure in monetary terms.

B. Use ISO 27001 to calculate annualized loss expectancy.

C. Use NIST SP 800-30 to determine exact financial loss values.

D. Use ISO 27005 to calculate return on security investment.

Q23: Explanation

Correct Answer: A

FAIR (Factor Analysis of Information Risk) is designed to quantify information risk in financial terms and supports cost-benefit and risk-based decision making.

Option Analysis

- **A - Correct:** FAIR provides quantitative estimates of probable loss exposure.
- **B - Incorrect:** ISO 27001 is an information security management standard, not a quantitative risk model.
- **C - Incorrect:** NIST SP 800-30 provides risk assessment guidance but does not produce precise financial loss calculations.
- **D - Incorrect:** ISO 27005 provides risk management guidance but is not primarily a quantitative financial analysis framework.

Q26: Supply Chain Risk Framework

Question

Which NIST framework provides guidance for supply chain management?

- A NIST 800-161
- B NIST 800-30
- C NIST 800-57
- D ISO 27001

Q26: Explanation

Correct Answer: A

NIST SP 800-161 provides guidance for supply chain risk management.

Option Analysis

- **A - Correct:** 800-161 is supply chain
- **B - Incorrect:** 800-30 is risk management
- **C - Incorrect:** 800-57 is key management
- **D - Incorrect:** ISO 27001 is management standard

Q27: Analysis

Question

Which risk assessment technique provides results by displaying links between possible causes, controls, and consequences in a diagram?

A. FAIR
B. BTA
C. Markov analysis
D. Monte Carlo analysis

Q27: Explanation

Correct Answer: B

Bow Tie Analysis (BTA) displays links between causes, controls, and consequences in a diagram.

Option Analysis

- **A - Incorrect:** FAIR is quantitative taxonomy
- **B - Correct:** BTA is diagram-based
- **C - Incorrect:** Markov uses state analysis
- **D - Incorrect:** Monte Carlo uses simulation

Q27: Risk Analysis Technique

Question

During a risk workshop, management wants to visualize how specific threat events could occur, the preventive controls in place, and the potential business consequences if those controls fail. Which risk assessment technique BEST meets this requirement?

- A FAIR
- B Bow Tie Analysis (BTA)
- C Markov Analysis
- D Monte Carlo Simulation

Q27: Explanation

Correct Answer: B

Bow Tie Analysis (BTA) visually illustrates the relationship between threats, preventive controls, the risk event, recovery controls, and resulting consequences.

Option Analysis

- **A - Incorrect:** FAIR focuses on quantifying risk in financial terms.
- **B - Correct:** BTA uses a visual diagram linking causes, controls, events, and consequences.
- **C - Incorrect:** Markov analysis models state transitions and probabilities.
- **D - Incorrect:** Monte Carlo simulation evaluates a range of possible outcomes using repeated calculations.

Q28: Risk Register Output

Question

The results of a risk assessment should be summarized as a(n):

A. CAP
B. Business continuity plan
C. Organizational chart
D. Risk register

Q28: Explanation

Correct Answer: D

Risk register is the immediate result of a risk assessment.

Option Analysis

- **A - Incorrect:** CAP is corrective action plan
- **B - Incorrect:** BCP is continuity planning
- **C - Incorrect:** Org chart shows structure
- **D - Correct:** Risk register documents risks

Q28: Risk Assessment Deliverable

Question

After completing an enterprise risk assessment, management wants a consolidated view of identified risks, their ratings, assigned owners, response plans, and monitoring status. Which document BEST fulfills this requirement?

- A Corrective Action Plan (CAP)
- B Business Continuity Plan (BCP)
- C Organizational Chart
- D Risk Register

Q28: Explanation

Correct Answer: D

A risk register is the primary repository for documenting identified risks, risk ratings, ownership, response strategies, and ongoing monitoring activities.

Option Analysis

- **A - Incorrect:** A CAP addresses remediation actions for specific issues, not the overall inventory of risks.
- **B - Incorrect:** A BCP focuses on continuity and recovery from disruptions.
- **C - Incorrect:** An organizational chart defines reporting relationships.
- **D - Correct:** A risk register is the standard output of a risk assessment process.

Q29: BIA vs Risk Assessment

Question

Which statement is false regarding risk assessment and BIA?

A. BIA identifies RPO, RTO, MTD

B. Risk assessment identifies mitigation plans

C. BCP needs BIA

D. BIA and risk assessment are the same

Q29: Explanation

Correct Answer: D

BIA and risk assessment are NOT the same.

Option Analysis

- **A - True:** BIA identifies recovery objectives
- **B - True:** Risk assessment identifies mitigation
- **C - True:** BCP needs BIA as input
- **D - Not True:** They are different processes

Q29: Business Impact Analysis vs. Risk Assessment

Question

Which statement BEST describes the relationship between a Business Impact Analysis (BIA) and a risk assessment?

A. Both processes identify threats and vulnerabilities.

B. A BIA determines business impact and recovery requirements, while a risk assessment evaluates risk likelihood and impact.

C. A risk assessment establishes RTOs and RPOs, while a BIA identifies threat scenarios.

D. Both processes produce identical outputs and can be used interchangeably.

Q29: Explanation

Correct Answer: B

A Business Impact Analysis determines the effect of disruptions on business operations and establishes recovery objectives. A risk assessment evaluates threats, vulnerabilities, likelihood, and impact to determine risk levels.

Option Analysis

- **A - Incorrect:** Threat and vulnerability identification is primarily part of risk assessment.
- **B - Correct:** BIA focuses on business impact and recovery requirements; risk assessment focuses on risk evaluation.
- **C - Incorrect:** RTO and RPO are outputs of a BIA.
- **D - Incorrect:** The two processes serve different purposes.

Q30: Recovery Objectives

Question

Which process is MOST likely to establish Recovery Time Objectives (RTOs)?

A. Risk Assessment
B. Vulnerability Assessment
C. Business Impact Analysis
D. Control Self-Assessment

Q30: Explanation

Correct Answer: C

BIA establishes RTOs, RPOs, MTDs, and recovery priorities.

- **A - Incorrect:** Risk assessment determines threats, vulnerabilities, likelihood, impact, and risk treatment. It does not establish recovery targets.
- **B - Incorrect:** Vulnerability assessments identify security weaknesses but do not determine business recovery objectives.
- **C - Correct:** BIA determines how quickly business services must be restored.
- **D - Incorrect:** Control Self-Assessment evaluates effectiveness of controls, not continuity requirements.

Q31: Threat Identification

Question

Which activity is primarily focused on identifying threats and vulnerabilities?

- A Business Impact Analysis
- B Risk Assessment
- C Disaster Recovery Planning
- D Business Continuity Testing

Q31: Explanation

Correct Answer: B

Risk assessment evaluates threats, vulnerabilities, likelihood, and impact.

- **A - Incorrect:** BIA asks "what happens if a process fails?" not "what causes the failure?"
- **B - Correct:** Threat and vulnerability identification is a core risk assessment activity.
- **C - Incorrect:** DRP focuses on recovering technology after a disruption.
- **D - Incorrect:** Testing validates recovery plans already created.

Q32: Maximum Downtime

Question

Maximum Tolerable Downtime (MTD) is determined during:

A. Risk Assessment
B. Business Impact Analysis
C. Penetration Testing
D. Risk Monitoring

Q32: Explanation

Correct Answer: B

MTD is a business recovery metric determined during BIA.

- **A - Incorrect:** Risk assessment determines risk levels rather than allowable downtime.
- **B - Correct:** BIA identifies how long a process can remain unavailable before unacceptable damage occurs.
- **C - Incorrect:** Penetration testing evaluates exploitability of vulnerabilities.
- **D - Incorrect:** Risk monitoring tracks changes in risks over time.

Q33: Residual Risk

Question

Residual risk is MOST likely to be evaluated during:

A. Business Impact Analysis
B. Business Continuity Planning
C. Risk Assessment
D. Disaster Recovery Testing

Q33: Explanation

Correct Answer: C

Residual risk is the risk remaining after controls operate.

- **A - Incorrect:** BIA focuses on business impact and recovery requirements.
- **B - Incorrect:** BCP develops continuity strategies, not risk calculations.
- **C - Correct:** Residual risk is measured during risk assessment and risk evaluation.
- **D - Incorrect:** DR testing validates recovery capability.

Q34: Critical Processes

Question

Which activity identifies business-critical processes and recovery priorities?

A. Risk Assessment
B. Business Impact Analysis
C. Control Assessment
D. Audit Planning

Q34: Explanation

Correct Answer: B

BIA identifies critical processes and their recovery priorities.

- **A - Incorrect:** Risk assessment identifies risks to processes, not which processes are most critical.
- **B - Correct:** BIA ranks processes based on business impact.
- **C - Incorrect:** Control assessment evaluates effectiveness of controls.
- **D - Incorrect:** Audit planning determines audit scope and resources.

Q35: Risk Response

Question

Risk avoidance, mitigation, transfer, and acceptance are outputs of:

A. Risk Assessment
B. Business Impact Analysis
C. Business Continuity Planning
D. Capacity Planning

Q35: Explanation

Correct Answer: A

These are the four classic risk response strategies.

- **A - Correct:** Risk assessment leads to risk treatment decisions.
- **B - Incorrect:** BIA determines business recovery requirements.
- **C - Incorrect:** BCP focuses on operational continuity during disruptions.
- **D - Incorrect:** Capacity planning manages resource utilization and growth.

Q30: RPO Direction

Question

Which is backward-looking in relation to BIA?

A. RPO
B. RTO
C. MTD
D. SSO

Q30: Explanation

Correct Answer: A

RPO (Recovery Point Objective) is backward-looking - it measures acceptable data loss.

Option Analysis

- **A - Correct:** RPO is backward-looking
- **B - Incorrect:** RTO is forward-looking
- **C - Incorrect:** MTD is total downtime
- **D - Incorrect:** SSO is single sign-on

Q30: RPO Direction

Question

Which metric is considered backward-looking when determining recovery requirements?

A. Recovery Point Objective (RPO)
B. Recovery Time Objective (RTO)
C. Maximum Tolerable Downtime (MTD)
D. Single Sign-On (SSO)

Q30: Explanation

Correct Answer: A

RPO looks backward from the disruption and defines the maximum acceptable amount of data loss measured in time.

- **A - Correct:** RPO answers: "How far back can we go and still recover without unacceptable data loss?"
- **B - Incorrect:** RTO is forward-looking. It answers: "How quickly must the system be restored after an outage?"
- **C - Incorrect:** MTD represents the maximum time a business process can remain unavailable before severe business damage occurs.
- **D - Incorrect:** SSO (Single Sign-On) is an authentication technology and is unrelated to BIA recovery metrics.

Q32: XXX Risk

Question

The risk after implementing controls in a real-time scenario against threats is called:

A. Residual risk
B. Inherent risk
C. Current risk
D. Total risk

Q32: Explanation

Correct Answer: C

Current risk is the residual risk in a real-time threat scenario at a specific point in time.

Option Analysis

- **A - Incorrect:** Residual is not real-time
- **B - Incorrect:** Inherent is before controls
- **C - Correct:** Current is real-time residual risk
- **D - Incorrect:** Total risk is before controls

Q33: Risk Owner Purpose

Question

The primary reason for having a risk owner is:

A. Leverage their resources
B. Ensure accountability
C. Provide flexibility
D. Seek assistance

Q33: Explanation

Correct Answer: B

The risk owner drives accountability in risk remediation.

Option Analysis

- **A - Incorrect:** Resources are secondary
- **B - Correct:** Accountability is primary
- **C - Incorrect:** Flexibility is not primary
- **D - Incorrect:** Assistance is secondary

Q33: Risk Owner Accountability

Question

What is the PRIMARY reason for assigning a risk owner to an identified risk?

A. To leverage the risk owner's resources
B. To ensure accountability for managing the risk
C. To provide flexibility in risk response decisions
D. To obtain assistance from subject matter experts

Q33: Explanation

Correct Answer: B

Risk ownership exists primarily to ensure that a specific individual is accountable for monitoring, responding to, and reporting on a risk.

- **A - Incorrect:** A risk owner may have resources to address a risk, but resources are not why ownership is assigned. Ownership is about responsibility, not budget or staffing.
- **B - Correct:** Accountability is the foundation of effective risk governance. Without a clearly assigned owner, risks may not be monitored, mitigated, or escalated appropriately.
- **C - Incorrect:** Flexibility can exist regardless of ownership. Assigning an owner establishes responsibility rather than increasing flexibility.
- **D - Incorrect:** Subject matter experts may support the owner, but they do not replace accountability. A risk can have many contributors but should have one accountable owner.

Q34: NOT a Risk Response Strategy

Question

Which is NOT a risk response strategy?

A. Accept
B. Transfer
C. Treat
D. Mitigate

Q34: Explanation

Correct Answer: C

"Treat" is sometimes used interchangeably but is not a formal risk response strategy. The four strategies are Accept, Transfer, Mitigate, and Avoid.

Option Analysis

- **A - Incorrect:** Accept is a strategy
- **B - Incorrect:** Transfer is a strategy
- **C - Correct:** Treat is not a formal strategy
- **D - Incorrect:** Mitigate is a strategy

Q35: Compensating Controls

Question

A risk manager determines primary controls are insufficient and implements compensating controls. This is:

- A Risk mitigation
- B Risk acceptance
- C Risk sharing
- D Risk avoidance

Q35: Explanation

Correct Answer: A

Implementing additional controls is an example of risk mitigation.

Option Analysis

- **A - Correct:** Adding controls is mitigation
- **B - Incorrect:** Acceptance would do nothing
- **C - Incorrect:** Sharing would involve third party
- **D - Incorrect:** Avoidance would terminate activity

Q35: Compensating Controls

Question

A risk manager determines existing controls are insufficient and implements compensating controls to reduce the likelihood of a risk event. Which risk response strategy is being applied?

- A Risk mitigation
- B Risk acceptance
- C Risk sharing
- D Risk avoidance

Q35: Explanation

Correct Answer: A

Implementing compensating controls reduces either the likelihood or impact of a risk and is therefore a form of risk mitigation.

- **A - Correct:** Risk mitigation reduces risk through controls, safeguards, monitoring, or process improvements.
- **B - Incorrect:** Risk acceptance means management knowingly accepts the residual risk without implementing additional controls.
- **C - Incorrect:** Risk sharing transfers part of the risk to another party, such as through insurance, outsourcing, or contractual agreements.
- **D - Incorrect:** Risk avoidance eliminates the activity giving rise to the risk altogether.

Q36: Insurance as Risk Response

Question

Senior management buys insurance for an earthquake-prone site. This is:

A. Risk mitigation
B. Risk acceptance
C. Risk sharing
D. Risk avoidance

Q36: Explanation

Correct Answer: C

Insurance transfers/sharing the risk with the insurance company.

Option Analysis

- **A - Incorrect:** Mitigation would reduce risk
- **B - Incorrect:** Acceptance would retain risk
- **C - Correct:** Sharing through insurance
- **D - Incorrect:** Avoidance would close site

Q36: Insurance as a Risk Response

Question

Senior management purchases insurance coverage for a data center located in an earthquake-prone region. Which risk response strategy is being applied?

- A Risk mitigation
- B Risk acceptance
- C Risk sharing
- D Risk avoidance

Q36: Explanation

Correct Answer: C

Insurance transfers part of the financial consequences of a loss to a third party and is therefore considered risk sharing (or risk transfer).

- **A - Incorrect:** Mitigation reduces the likelihood or impact of a risk through controls. Insurance does not prevent earthquakes or reduce their probability.
- **B - Incorrect:** Acceptance means management knowingly retains the risk without additional treatment. Purchasing insurance is a deliberate treatment strategy.
- **C - Correct:** Insurance shifts part of the financial burden to the insurer. The organization still experiences the event, but shares the loss.
- **D - Incorrect:** Avoidance eliminates the activity creating the risk. For example, relocating the data center away from the earthquake zone would be risk avoidance.

Q37: Risk What to do

Question

Management terminates onboarding a new tool as it doesn't adapt to changing requirements. This is:

A. Risk mitigation
B. Risk acceptance
C. Risk sharing
D. Risk avoidance

Q37: Explanation

Correct Answer: D

Terminating a project to eliminate risk is risk avoidance.

Option Analysis

- **A - Incorrect:** Mitigation would modify the tool
- **B - Incorrect:** Acceptance would proceed with risk
- **C - Incorrect:** Sharing would involve third party
- **D - Correct:** Avoidance eliminates the risk

Q37: Product Modernization Decision

Question

During implementation of a new enterprise platform, management determines the solution cannot support anticipated regulatory requirements and would require extensive future redevelopment. After reviewing the projected costs and risks, management decides not to proceed with implementation. Which risk response strategy has management selected?

A. Risk mitigation
B. Risk acceptance
C. Risk sharing
D. Risk avoidance

Q37: Explanation

Correct Answer: D

By deciding not to proceed with the project, management eliminates the exposure associated with the initiative.

- **A - Incorrect:** Mitigation would involve implementing controls or redesigning the solution while continuing the project.
- **B - Incorrect:** Acceptance would mean proceeding despite the identified concerns.
- **C - Incorrect:** Sharing would involve transferring part of the risk through contracts, insurance, or third parties.
- **D - Correct:** Cancelling the initiative eliminates the source of the risk and is therefore risk avoidance.

Q46: Risk Treatment Strategy

Question

An organization identifies a concentration risk resulting from a critical business process being performed by a single employee. Management implements cross-training and succession procedures to reduce the likelihood of operational disruption. Which risk response strategy is MOST appropriate?

- A Risk mitigation
- B Risk acceptance
- C Risk sharing
- D Risk avoidance

Correct Answer: A Explanation: Cross-training and succession planning reduce the likelihood and impact of disruption while allowing the activity to continue. This is an example of risk mitigation. **Option Analysis A -**

Correct: Risk Mitigation Additional controls were implemented to reduce operational risk. The activity continues, but exposure is reduced. **B**

Q39: SLA Breach

Question

Which would bind a third party to provide monetary credits in case of service failure?

A. Master service agreement
B. Service-level agreement
C. Non-disclosure agreement
D. External audit

Q39: Explanation

Correct Answer: B

A breach in the SLA allows the organization to demand monetary credit.

Option Analysis

- **A - Incorrect:** MSA is general framework
- **B - Correct:** SLA defines service levels and penalties
- **C - Incorrect:** NDA protects confidentiality
- **D - Incorrect:** Audit is verification

Q39: Third-Party Service Risk

Question

A critical application is hosted by a cloud provider. Management wants contractual recourse if system availability falls below agreed performance thresholds.
Which document would MOST directly establish measurable uptime targets and associated service credits?

- A Master Service Agreement (MSA)
- B Service-Level Agreement (SLA)
- C Non-Disclosure Agreement (NDA)
- D Independent Assurance Report

Q39: Explanation

Correct Answer: B - Service-Level Agreement (SLA)

An SLA defines measurable performance obligations such as uptime, response times, and service credits when agreed service levels are not achieved. When an organization seeks contractual remedies for poor service performance, the SLA is the document that provides the specific performance commitments and associated penalties.

Option Analysis

A - Incorrect: Master Service Agreement (MSA)
The MSA establishes the overall legal and commercial framework governing the relationship between the customer and the service provider. It commonly addresses liability, payment terms, governance requirements, dispute resolution procedures, and general contractual obligations. Candidates are often tempted to choose the MSA because it is the primary contract between the parties. However, detailed service-performance metrics, uptime guarantees, and service-credit provisions are normally

Q40: NDA Purpose

Question

Which should be signed with third party to protect intellectual property?

- A Master service agreement
- B Service-level agreement
- C Non-disclosure agreement
- D External audit

Q40: Explanation

Correct Answer: C

NDAs protect intellectual property and interests of the organization.

Option Analysis

- **A - Incorrect:** MSA is general framework
- **B - Incorrect:** SLA defines service levels
- **C - Correct:** NDA protects IP and confidentiality
- **D - Incorrect:** Audit is verification

Q41: External Audit Output

Question

Which is NOT the final output of an external audit?

- A SOC 2 report
- B ISO 27001 certification
- C HITRUST certification
- D Non-disclosure agreement

Q41: Explanation

Correct Answer: D

Non-disclosure agreements are signed internally, not the output of an external audit.

Option Analysis

- **A - Incorrect:** SOC 2 is audit output
- **B - Incorrect:** ISO 27001 is audit output
- **C - Incorrect:** HITRUST is audit output
- **D - Correct:** NDA is not an audit output

Q41: Third-Party Assurance

Question

A bank is assessing a critical cloud provider and wants independent evidence that security controls operate effectively. Which would LEAST help satisfy this requirement?

- A SOC 2 Type II report
- B ISO 27001 certification
- C HITRUST certification
- D Non-Disclosure Agreement (NDA)

Q41: Explanation

Correct Answer: D

An NDA protects confidential information but does not provide assurance that security controls are designed or operating effectively.

Option Analysis

A - Incorrect: A SOC 2 Type II report provides independent assurance regarding the effectiveness of controls. **B - Incorrect:** ISO 27001 certification demonstrates that an information security management system has been assessed against a recognized standard. **C - Incorrect:** HITRUST certification provides independent validation of security and compliance controls. **D - Correct:** An NDA governs confidentiality obligations but does not verify the existence or effectiveness of controls.

CRISC Tip

Assurance = SOC, ISO, HITRUST. Confidentiality = NDA.

Q42: Exception Review Frequency

Question

The risk practitioner should review and verify granted exceptions are still required at least:

A. Weekly
B. Monthly
C. Quarterly
D. Annually

Q42: Explanation

Correct Answer: D

Granted exceptions should be verified at least annually.

Option Analysis

- **A - Incorrect:** Weekly is too frequent
- **B - Incorrect:** Monthly is too frequent
- **C - Incorrect:** Quarterly is too frequent
- **D - Correct:** Annual review is standard

CRISC Exam Tip

Whenever you see "exception," think: approval, documentation, compensating controls, risk owner, expiration date, and periodic review.

Q42: Policy Exception Governance

Question

A business unit was granted an exception to the organization's encryption standard because a legacy application could not support the required controls. The compensating controls remain in place, and the exception was approved by management. What should the risk practitioner do NEXT?

- A Close the exception because management approved it
- B Review the exception periodically to ensure it remains justified
- C Transfer ownership of the exception to the vendor
- D Remove the compensating controls

Q42: Explanation

Correct Answer: B

Approved exceptions should be periodically reviewed to confirm they remain necessary, justified, and within the organization's risk appetite.

Option Analysis

A - Incorrect: Management approval does not eliminate the need for ongoing oversight. Risk exceptions require periodic review because business conditions, technology, and risk exposure can change. **B - Correct:** Exception governance requires regular reassessment to determine whether the original justification remains valid and whether the exception should be renewed, modified, or terminated. **C - Incorrect:** Risk ownership and accountability remain with the organization even when third parties are involved. **D - Incorrect:** Compensating controls were implemented to reduce risk exposure. Removing them would increase residual risk.

Q43: CAB Composition

Question

The CAB should consist of which of the following?

A. Only IT
B. IT and engineering
C. IT, engineering, and security
D. All relevant stakeholders

Q43: Explanation

Correct Answer: D

CAB should consist of all relevant stakeholders.

Option Analysis

- **A - Incorrect:** IT alone is insufficient
- **B - Incorrect:** Engineering alone is insufficient
- **C - Incorrect:** Security is needed but not sufficient
- **D - Correct:** All relevant stakeholders needed

Q44: Control Categories

Question

Which is NOT a control category?

A. Additive
B. Preventive
C. Deterrent
D. Detective

Q44: Explanation

Correct Answer: A

Additive is not a control category. The categories are Preventive, Detective, Corrective, Deterrent, Compensating.

Option Analysis

- **A - Correct:** Additive is not a control category
- **B - Incorrect:** Preventive is a category
- **C - Incorrect:** Deterrent is a category
- **D - Incorrect:** Detective is a category

Q44: Control Classification

Question

A financial institution implements multi-factor authentication to reduce the likelihood of unauthorized access to customer accounts. How should this control BEST be classified?

- A Detective
- B Corrective
- C Preventive
- D Compensating

Q44: Explanation

Correct Answer: C

Multi-factor authentication attempts to stop unauthorized access before it occurs. Controls that reduce the likelihood of an event are preventive controls.

Option Analysis

A - Incorrect: Detective Detective controls identify events that have already occurred. Examples include log reviews, security monitoring, intrusion detection systems, and audit trails. These controls provide visibility but do not stop the initial event. **B - Incorrect: Corrective** Corrective controls restore systems after an incident has occurred. Examples include backup restoration, incident response activities, and disaster recovery procedures. C - Correct: Preventive Preventive controls attempt to stop undesirable events before they happen. Examples include MFA, segregation of duties, encryption, firewalls, and access controls.
D - Incorrect: Compensating Compensating controls are alternative controls used when a primary control cannot be implemented. For example, increased monitoring may compensate for a system that cannot support MFA.

Q45: Proactive Control

Question

Implementing controls proactively based on root cause analysis is an example of:

A. Preventive
B. Detective
C. Corrective
D. Compensating

Q45: Explanation

Correct Answer: A

Implementing controls proactively is an example of preventive control.

Option Analysis

- **A - Correct:** Preventive stops issues before they occur
- **B - Incorrect:** Detective finds issues after
- **C - Incorrect:** Corrective fixes issues after
- **D - Incorrect:** Compensating compensates for weaknesses

Q46: Which Control

Question

Reviewing audit logs in a SIEM tool is an example of:

A. Corrective control
B. Detective control
C. Compensating control
D. Deterrent control

Q46: Explanation

Correct Answer: B

Reviewing audit logs is detective control - it identifies issues after they occur.

Option Analysis

- **A - Incorrect:** Corrective fixes issues
- **B - Correct:** Detective identifies issues
- **C - Incorrect:** Compensating compensates
- **D - Incorrect:** Deterrent discourages actions

Q46: Security Monitoring

Question

During a security review, an analyst uses a SIEM platform to identify unusual login activity and investigate potential unauthorized access attempts. Which type of control is MOST evident?

- A Corrective control
- B Detective control
- C Compensating control
- D Deterrent control

CRISC Exam Tip

Preventive = Stop Detective = Discover Corrective = Recover Deterrent = Discourage Compensating = Alternative

Q46: Explanation

Correct Answer: B - Detective Control

Reviewing security events and audit logs allows an organization to identify suspicious activity after it occurs. The primary purpose is detection rather than prevention or recovery.

Option Analysis

A - Incorrect: Corrective Control Corrective controls are used after an incident has been detected to restore normal operations or reduce damage. Examples include restoring backups, rebuilding systems, and incident-response activities. A SIEM helps discover problems but does not correct them. **B - Correct: Detective Control** SIEM solutions collect and analyze logs to identify suspicious behavior, policy violations, and security incidents. The objective is to detect events that have already occurred or are currently occurring. **C - Incorrect: Compensating Control** Compensating controls serve as alternatives when a primary control cannot be implemented. For example, increased monitoring may compensate for the inability to deploy a stronger preventive control. In this scenario, the question focuses on log review itself, which is detective in nature. **D - Incorrect: Deterrent Control** Deterrent controls discourage undesirable behavior. Examples include warning banners, sanctions policies, surveillance notices, and visible security presence. These controls influence behavior but do not identify actual incidents.

Q47: Deterrent Control

Question

Installing security cameras to secure a data center is:

A. Corrective control
B. Detective control
C. Compensating control
D. Deterrent control

Q47: Explanation

Correct Answer: D

Security cameras are a deterrent control - they discourage malicious activity.

Option Analysis

- **A - Incorrect:** Corrective would fix issues
- **B - Incorrect:** Detective would identify issues
- **C - Incorrect:** Compensating would compensate
- **D - Correct:** Deterrent discourages activity

Q48: Which Control

Question

A risk manager introduced additional oversight of an accounting system where logical controls are not implemented. This is:

- A Corrective control
- B Detective control
- C Compensating control
- D Deterrent control

Q48: Explanation

Correct Answer: C

Additional oversight compensating for missing logical controls is a compensating control.

Option Analysis

- **A - Incorrect:** Corrective would fix the issue
- **B - Incorrect:** Detective would identify
- **C - Correct:** Compensating compensates for weakness
- **D - Incorrect:** Deterrent would discourage

Q49: Which Control

Question

An IT system failed during changes and lost data. Risk manager advises restoring from backups. This is:

- A Corrective control
- B Detective control
- C Compensating control
- D Deterrent control

Q49: Explanation

Correct Answer: A

Restoring from backups to fix an issue is a corrective control.

Option Analysis

- **A - Correct:** Corrective fixes the issue
- **B - Incorrect:** Detective would identify
- **C - Incorrect:** Compensating would compensate
- **D - Incorrect:** Deterrent would discourage

Q50: Post-Incident Controls

Question

Which control categories are used after the incident has happened?

A. Corrective, compensating
B. Corrective, deterrent
C. Corrective, detective
D. Deterrent, preventive

Q50: Explanation

Correct Answer: C

Detective and corrective controls are used after the incident has happened.

Option Analysis

- **A - Incorrect:** Compensating is ongoing
- **B - Incorrect:** Deterrent is before
- **C - Correct:** Detective and corrective are after
- **D - Incorrect:** Deterrent/preventive are before

Q51: Parallel Changeover

Question

Risk manager overseeing critical system upgrade with no downtime. Recommendation should be:

A. Parallel
B. Phased
C. Abrupt
D. Any of the above

Q51: Explanation

Correct Answer: A

Parallel changeover allows both systems to run simultaneously with no downtime.

Option Analysis

- **A - Correct:** Parallel ensures no downtime
- **B - Incorrect:** Phased may have downtime
- **C - Incorrect:** Abrupt has high risk
- **D - Incorrect:** Parallel is best for no downtime

Q52: Changeover

Question

System upgrading per module with no dependencies. Most efficient method?

- A Parallel
- B Phased
- C Abrupt
- D Any of the above

Q52: Explanation

Correct Answer: B

Phased changeover is most efficient when modules are independent.

Option Analysis

- **A - Incorrect:** Parallel is expensive
- **B - Correct:** Phased works well with independent modules
- **C - Incorrect:** Abrupt is too risky
- **D - Incorrect:** Phased is most efficient

Q52: System Implementation Strategy

Question

A bank is replacing a legacy application with a modular solution. Each module can operate independently and can be implemented without affecting the others. Which implementation approach would MOST efficiently reduce deployment risk while allowing incremental rollout?

- A Parallel changeover
- B Phased changeover
- C Abrupt changeover
- D Pilot changeover

Q52: Explanation

Correct Answer: B - Phased Changeover

Phased implementation allows independent modules to be deployed incrementally. This reduces implementation risk while avoiding the cost and complexity of operating both systems simultaneously.

Option Analysis

A - Incorrect: Parallel Changeover Parallel implementation operates the old and new systems simultaneously. While it provides strong fallback capability, it is resource-intensive and generally more expensive than necessary when modules can be migrated independently. **B - Correct: Phased Changeover** Phased changeover introduces functionality gradually. Independent modules can be implemented sequentially, allowing issues to be isolated and resolved with reduced operational impact. **C - Incorrect: Abrupt Changeover** Abrupt (or direct) changeover replaces the entire system at once. Although it may be faster, it introduces greater implementation risk because rollback options are limited. **D - Incorrect: Pilot Changeover** A pilot approach deploys the new system to a limited group of users or locations before broader implementation. This reduces risk but does not specifically leverage the independence of individual modules.

Q53: Post-Implementation Audience

Question

Who should be the target audience for a post-implementation review?

A. Developers
B. Risk manager
C. Risk owner
D. All major stakeholders

Q53: Explanation

Correct Answer: D

All major stakeholders should participate in post-implementation review.

Option Analysis

- **A - Incorrect:** Developers alone insufficient
- **B - Incorrect:** Risk manager alone insufficient
- **C - Incorrect:** Risk owner alone insufficient
- **D - Correct:** All stakeholders needed

Q54: Log Aggregation Purpose

Question

What is the primary purpose of log aggregation in an organization?

- A Identify and analyze important events
- B Synchronize clocks
- C Eliminate need for logging
- D Provide centralized storage only

Q54: Explanation

Correct Answer: A

Log aggregation helps identify and analyze important events and potential incidents.

Option Analysis

- **A - Correct:** Identification and analysis of events
- **B - Incorrect:** Clock sync is separate
- **C - Incorrect:** Doesn't eliminate logging
- **D - Incorrect:** Storage is not primary purpose

Q55: Log Tool

Question

Which is a commonly used tool for log aggregation and analysis?

- A SIEM system
- B Vulnerability assessment tool
- C Penetration testing tool
- D Heat map generator

Q55: Explanation

Correct Answer: A

SIEM systems are commonly used for log aggregation and analysis.

Option Analysis

- **A - Correct:** SIEM handles log aggregation
- **B - Incorrect:** VA tools find vulnerabilities
- **C - Incorrect:** Pen testing finds exploits
- **D - Incorrect:** Heat maps are visualization

Q55: Security Monitoring

Question

During a security incident investigation, analysts need to collect logs from firewalls, servers, databases, and applications into a centralized platform where events can be correlated and analyzed. Which technology BEST supports this requirement?

A. Security Information and Event Management (SIEM)

B. Vulnerability Assessment Tool

C. Penetration Testing Tool

D. Risk Heat Map

CRISC Exam Tip

Think about the primary purpose: SIEM = Log Collection and Monitoring Vulnerability Scanner = Find Weaknesses Penetration Testing = Exploit Weaknesses Heat Map = Visualize Risk

Q55: Explanation

Correct Answer: A - Security Information and Event Management (SIEM)

SIEM platforms aggregate, normalize, correlate, and analyze logs from multiple sources, providing organizations with centralized monitoring and incident-detection capabilities.

Option Analysis

A - Correct: Security Information and Event Management (SIEM) SIEM solutions collect logs from numerous systems and correlate events to identify suspicious activity, security incidents, and policy violations. This makes SIEM the preferred solution for centralized log monitoring and analysis. **B - Incorrect: Vulnerability Assessment Tool** Vulnerability assessment tools identify known security weaknesses and missing patches. Although they help identify security risks, they do not primarily function as centralized log management platforms. **C - Incorrect: Penetration Testing Tool** Penetration-testing tools are used to simulate attacks and identify exploitable weaknesses. Their purpose is to evaluate security posture rather than continuously aggregate and analyze operational logs. **D - Incorrect: Risk Heat Map** A risk heat map is a reporting and visualization technique used to communicate risk levels based on likelihood and impact. It may use information derived from security events but does not perform log collection or event correlation.

Q56: KRI Role

Question

What is the role of KRIs in risk monitoring?

- A Predict risks that may breach thresholds
- B Measure effectiveness of controls
- C Indicate weaknesses in controls
- D Assess control performance

Q56: Explanation

Correct Answer: A

KRIs predict risks that may breach predefined thresholds.

Option Analysis

- **A - Correct:** KRIs predict risk breaches
- **B - Incorrect:** KPIs measure effectiveness
- **C - Incorrect:** KCIs indicate weaknesses
- **D - Incorrect:** KPIs assess performance

Q56: Risk Monitoring Metrics

Question

A bank's risk committee receives a report showing that the number of failed privileged-access login attempts has increased by 40% over the past quarter. Management is concerned that the trend may indicate increasing cybersecurity risk and could eventually exceed approved risk tolerance levels. Which metric is MOST likely being used?

- A Key Risk Indicator (KRI)
- B Key Performance Indicator (KPI)
- C Key Control Indicator (KCI)
- D Key Audit Indicator (KAI)

CRISC Exam Tip

KRI = Is risk increasing? KPI = Is the business performing? KCI = Are controls working?

Q56: Explanation

Correct Answer: A - Key Risk Indicator (KRI)

KRIs provide early warning signals that risk exposure may be increasing and could eventually exceed established thresholds or risk appetite.

Option Analysis

A - Correct: Key Risk Indicator (KRI) KRIs are forward-looking measures designed to identify changes in risk exposure. An increasing number of failed privileged-access attempts may indicate growing cyber threats and warrant additional monitoring or management attention. **B - Incorrect: Key Performance Indicator (KPI)** KPIs measure business or operational performance. Examples include transaction-processing time, customer satisfaction, or system availability. The scenario focuses on increasing risk exposure rather than operational performance. **C - Incorrect: Key Control Indicator (KCI)** KCIs measure whether controls are operating effectively. Examples include patch compliance rates, MFA enrollment percentages, or completion of access reviews. The scenario measures risk trends, not control effectiveness. **D - Incorrect: Key Audit Indicator (KAI)** This is a distractor. CRISC commonly discusses KRIs, KPIs, and KCIs. The metric described in the scenario is specifically related to monitoring risk exposure.

Q57: Dashboard Characteristics

Question

Which format of risk reporting is known for flexibility in combining qualitative and quantitative metrics?

A. Executive summary
B. Heat map
C. Scorecard
D. Dashboard

Q57: Explanation

Correct Answer: D

Dashboards combine qualitative and quantitative metrics with flexibility.

Option Analysis

- **A - Incorrect:** Summary is text-based
- **B - Incorrect:** Heat map is qualitative only
- **C - Incorrect:** Scorecard is qualitative
- **D - Correct:** Dashboard is flexible

Q58: SMART Metrics

Question

What are the key characteristics of a SMART metric?

A. Specific, Measurable, Attainable, Relevant, Timely
B. Standardized, Meaningful, Achievable, Realistic, Timeless
C. Secure, Measurable, Aligned, Reliable, Trustworthy
D. Significant, Measurable, Accurate, Relevant, Timed

Q58: Explanation

Correct Answer: A

SMART stands for Specific, Measurable, Attainable, Relevant, Timely.

Option Analysis

- **A - Correct:** Standard SMART definition
- **B - Incorrect:** Not standard SMART
- **C - Incorrect:** Not standard SMART
- **D - Incorrect:** Not standard SMART

Q59: Attack Testing

Question

Which technique involves simulating a real attack to identify undiscovered vulnerabilities?

A. Self-assessment
B. Internal audit
C. Vulnerability assessment
D. Penetration testing

Q59: Explanation

Correct Answer: D

Penetration testing simulates real attacks to identify vulnerabilities.

Option Analysis

- **A - Incorrect:** Self-assessment is internal review
- **B - Incorrect:** Audit is compliance review
- **C - Incorrect:** VA finds known vulnerabilities
- **D - Correct:** Penetration test simulates attacks

Q60: Technology Architecture

Question

Networking devices, storage, and software are components of:

A. Business architecture
B. Technology architecture
C. Data architecture
D. Application architecture

Q60: Explanation

Correct Answer: B

Networking devices, storage, and software are components of technology architecture.

Option Analysis

- **A - Incorrect:** Business architecture defines processes
- **B - Correct:** Technology architecture covers infrastructure
- **C - Incorrect:** Data architecture covers data management
- **D - Incorrect:** Application architecture covers software solutions

Q61: CMM Defined Process

Question

Which is NOT a property of the Defined process in CMM?

A. Well characterized and understood
B. Defined at organizational level
C. Proactive
D. Unpredictable

Q61: Explanation

Correct Answer: D

Unpredictable is not a property of Defined process in CMM.

Option Analysis

- **A - True:** Well characterized
- **B - True:** Defined at organizational level
- **C - True:** Proactive
- **D - Not True:** Defined processes are predictable

Q61: CMM Defined Process

Question

Which of the following is NOT a characteristic of a Level 3 (Defined) process in the Capability Maturity Model (CMM)?

A. Processes are standardized across the organization
B. Processes are documented and communicated
C. Processes are primarily dependent on individual effort
D. Processes are well understood by personnel

Memory Aid

Level 1 = Ad Hoc Level 2 = Repeatable Level 3 = Defined Level 4 = Measured Level 5 = Optimized

Q61: Explanation

Correct Answer: C

A Level 3 (Defined) process is organizationally standardized, documented, and understood. Dependence on individual effort is characteristic of lower maturity levels.

Option Analysis

A - **Incorrect** Standardization across the organization is a defining characteristic of Level 3 maturity. **B** - **Incorrect** Defined processes are formally documented and communicated throughout the organization. **C** - **Correct** Heavy reliance on individual effort indicates an ad hoc or immature process rather than a defined process. **D** - **Incorrect** Personnel should understand and consistently follow defined processes.

Q62: TCP/IP Model Layers

Question

Which is Layer 3 of the TCP/IP model?

- A Physical
- B Data link
- C Network
- D Application

Q62: Explanation

Correct Answer: C

Network layer is Layer 3 of the TCP/IP model.

Option Analysis

- **A - Incorrect:** Physical is Layer 1
- **B - Incorrect:** Data link is Layer 2
- **C - Correct:** Network is Layer 3
- **D - Incorrect:** Application is Layer 5

Q63: OSI Model Session Layer

Question

Which is Layer 5 of the OSI model?

- A Physical
- B Application
- C Session
- D Transport

Q63: Explanation

Correct Answer: C

Session layer is Layer 5 of the OSI model.

Option Analysis

- **A - Incorrect:** Physical is Layer 1
- **B - Incorrect:** Application is Layer 7
- **C - Correct:** Session is Layer 5
- **D - Incorrect:** Transport is Layer 4

Q64: VPN Protocol

Question

Which protocol is used to implement a VPN?

A. DNS
B. IPSec
C. SSL
D. SSO

Q64: Explanation

Correct Answer: B

IPSec protocol is commonly used to implement VPNs.

Option Analysis

- **A - Incorrect:** DNS is domain name service
- **B - Correct:** IPSec enables VPN
- **C - Incorrect:** SSL is for web encryption
- **D - Incorrect:** SSO is single sign-on

Q65: IaaS

Question

Which is an example of on-demand compute, network, and storage services?

A. PaaS
B. SaaS
C. IaaS
D. NaaS

Q65: Explanation

Correct Answer: C

IaaS provides on-demand compute, network, and storage services.

Option Analysis

- **A - Incorrect:** PaaS provides platform
- **B - Incorrect:** SaaS provides software
- **C - Correct:** IaaS provides infrastructure
- **D - Incorrect:** NaaS provides network services

Q66: SaaS Example

Question

An online platform for video games is an example of:

A. PaaS
B. SaaS
C. IaaS
D. NaaS

Q66: Explanation

Correct Answer: B

Online video game platform that lets users play without installing software is SaaS.

Option Analysis

- **A - Incorrect:** PaaS provides development platform
- **B - Correct:** SaaS provides ready-to-use software
- **C - Incorrect:** IaaS provides infrastructure
- **D - Incorrect:** NaaS provides network

Q67: Private Cloud

Question

In which deployment model are underlying cloud services NOT shared with other customers?

A. Public
B. Private
C. Community
D. Hybrid

Q67: Explanation

Correct Answer: B

Private cloud resources are dedicated to a single organization.

Option Analysis

- **A - Incorrect:** Public is shared
- **B - Correct:** Private is dedicated
- **C - Incorrect:** Community is shared with similar orgs
- **D - Incorrect:** Hybrid combines models

Q68: Community Cloud

Question

In which deployment model are underlying cloud services shared with similar customers?

A. Public
B. Private
C. Community
D. Hybrid

Q68: Explanation

Correct Answer: C

Community cloud lets similar organizations share resources.

Option Analysis

- **A - Incorrect:** Public is open to all
- **B - Incorrect:** Private is dedicated
- **C - Correct:** Community is for similar orgs
- **D - Incorrect:** Hybrid combines models

Q69: BIA Input for BCP

Question

Which acts as an input for the BCP?

A. Recovery objectives
B. DR test
C. BIA
D. BC test

Q69: Explanation

Correct Answer: C

BIA is the input to creating a BCP.

Option Analysis

- **A - Incorrect:** Recovery objectives are output of BIA
- **B - Incorrect:** DR test validates recovery
- **C - Correct:** BIA inputs BCP
- **D - Incorrect:** BC test validates BCP

Q69: Business Continuity Planning

Question

Which of the following is a primary input used when developing a Business Continuity Plan (BCP)?

- A Recovery Time Objective (RTO)
- B Disaster Recovery Test Results
- C Business Impact Analysis (BIA)
- D Business Continuity Test Results

Memory Aid

BIA $\rightarrow$ BCP BIA outputs RTO, RPO, MTD BCP is built using BIA results BC/DR Tests validate the completed plan

Q69: Explanation

Correct Answer: C - Business Impact Analysis (BIA)

The BIA identifies critical business processes, dependencies, recovery priorities, RTOs, RPOs, and business impacts. These findings provide the foundation for developing a Business Continuity Plan.

Option Analysis

A - Incorrect: Recovery Time Objective (RTO) RTO is not an input to the BIA. Instead, it is one of the key outputs produced by the BIA and later incorporated into the BCP. **B - Incorrect: Disaster Recovery Test Results** DR test results validate the effectiveness of recovery procedures after plans have already been developed. They improve and refine the BCP but are not primary inputs to its creation. **C - Correct:**

Business Impact Analysis (BIA) The BIA identifies critical processes, business impacts, dependencies, recovery requirements, and recovery objectives. These results are used to develop continuity and recovery strategies. **D - Incorrect: Business Continuity Test Results** BC test results evaluate whether the BCP works as intended. Testing occurs after plan development and therefore cannot be considered a primary input.

Q70: RPO

Question

Risk manager confirms application can't lose more than four hours of data. Which objective is this?

A. MTD
B. RPO
C. RTO
D. BIA

Q70: Explanation

Correct Answer: B

RPO is the maximum acceptable data loss - in this case, 4 hours.

Option Analysis

- **A - Incorrect:** MTD is total downtime
- **B - Correct:** RPO measures data loss tolerance
- **C - Incorrect:** RTO measures downtime tolerance
- **D - Incorrect:** BIA is the assessment process

Q70: RPO

Question

A risk manager confirms a critical application cannot lose more than four hours of data following a disruption. Which recovery objective does this requirement represent?

- A Maximum Tolerable Downtime (MTD)
- B Recovery Point Objective (RPO)
- C Recovery Time Objective (RTO)
- D Business Impact Analysis (BIA)

Memory Aid

RPO = Data Loss ("How much data can we lose?") RTO = Downtime ("How long can systems be down?") MTD = Survival Limit ("How long can the business survive?")

Q70: Explanation

Correct Answer: B - Recovery Point Objective (RPO)

RPO represents the maximum acceptable amount of data loss measured in time. If no more than four hours of data can be lost, the RPO is four hours.

Option Analysis

A - Incorrect: Maximum Tolerable Downtime (MTD) MTD measures how long a business process can remain unavailable before unacceptable business damage occurs. It focuses on business survival, not data loss. **B - Correct: Recovery Point Objective (RPO)** RPO measures allowable data loss. A four-hour RPO means recovery may require restoring data up to four hours before the disruption. **C - Incorrect: Recovery Time Objective (RTO)** RTO measures how quickly a system must be restored after an outage. It focuses on downtime rather than lost data. **D - Incorrect: Business Impact Analysis (BIA)** BIA is the process used to identify business impacts and establish recovery requirements such as RTO, RPO, and MTD. It is not itself a recovery objective.

Q71: RTO and MTD

Question

An application can tolerate four hours of downtime but must be recovered within six hours. Which metrics are correct?

- A RPO - 4h, RTO - 6h
- B MTD - 4h, RTO - 6h
- C MTD - 6h, RPO - 4h
- D RTO - 4h, MTD - 6h

Q71: Explanation

Correct Answer: D

RTO is maximum acceptable downtime (4h). MTD is maximum total downtime before material impact (6h).

Option Analysis

- **A - Incorrect:** RPO is data loss, not downtime
- **B - Incorrect:** MTD should be 6h, not 4h
- **C - Incorrect:** MTD is 6h not 4h
- **D - Correct:** RTO=4h (downtime tolerance), MTD=6h (total before impact)

Q71: RTO vs MTD

Question

A Business Impact Analysis determines that a critical application must be recovered within four hours of an outage. The business can tolerate no more than six hours of total disruption before severe operational impact occurs. Which of the following is correct?

- A RPO = 4 hours, RTO = 6 hours
- B MTD = 4 hours, RTO = 6 hours
- C MTD = 6 hours, RPO = 4 hours
- D RTO = 4 hours, MTD = 6 hours

Memory Aid

RPO = Data Loss RTO = Recovery Target MTD = Business Survival Limit Rule: RTO should always be less than or equal to MTD.

Q71: Explanation

Correct Answer: D

RTO is the target recovery time for the system, while MTD is the maximum amount of downtime the business can tolerate before unacceptable consequences occur.

Option Analysis

A - **Incorrect** RPO measures acceptable data loss, not downtime. The scenario provides no information regarding data loss. **B** - **Incorrect** The application must be recovered within four hours, making the RTO four hours. The business can tolerate six hours of disruption, making the MTD six hours. **C** - **Incorrect** MTD equals six hours, but there is no information concerning data loss, so RPO cannot be determined. **D** - **Correct** RTO = 4 hours because recovery must occur within four hours. MTD = 6 hours because the business cannot tolerate disruption beyond six hours.

Q72: Data Classification

Question

Healthcare records and driver's licenses - most appropriate classification?

A. Sensitive (PII and PHI)
B. Public
C. PII
D. PHI

Q72: Explanation

Correct Answer: A

Contains both PII and PHI, so classification should be Sensitive.

Option Analysis

- **A - Correct:** Sensitive covers both PII and PHI
- **B - Incorrect:** Public is for non-sensitive data
- **C - Incorrect:** PII alone doesn't cover health records
- **D - Incorrect:** PHI alone doesn't cover driver's licenses

Q74: Data Labeling Purpose

Question

Data labeling is important for which of the following?

A. Data archival
B. Data destruction
C. DLP
D. All of the above

Q74: Explanation

Correct Answer: D

Data labeling is important for archival, destruction, and DLP.

Option Analysis

- **A - Incorrect:** Archival alone not complete
- **B - Incorrect:** Destruction alone not complete
- **C - Incorrect:** DLP alone not complete
- **D - Correct:** All functions benefit from labeling

Q74: Data Classification

Question

Why is data classification and labeling important from a risk management perspective?

A. It helps determine appropriate retention and archival requirements
B. It helps determine appropriate disposal and destruction requirements
C. It enables enforcement of data loss prevention (DLP) controls
D. All of the above

Q74: Explanation

Correct Answer: D - All of the Above

Data labeling identifies the sensitivity and classification of information. Organizations rely on these labels throughout the information lifecycle to determine how data should be stored, protected, retained, shared, archived, and ultimately destroyed.

Option Analysis

A - Incorrect Data classification assists with retention and archival decisions because different categories of information may be subject to different legal, regulatory, or business retention requirements. However, this is only one use of labeling. **B - Incorrect** Data labels help determine destruction requirements. For example, confidential customer information may require secure deletion, whereas public information may not require special disposal procedures. However, this is not the only purpose of labeling. **C - Incorrect** DLP technologies often rely on data classification labels to identify sensitive information and prevent unauthorized transmission, copying, or disclosure. However, labeling supports many other governance and security functions as well. **D - Correct** Data labeling supports the entire information lifecycle, including protection, DLP enforcement, retention, archival, legal holds, access control decisions, and secure destruction.

Q76: User Training Phase

Question

End user training is an integral part of which phase of the SDLC?

- A Development
- B Disposal
- C Initiation
- D Implementation

Q76: Explanation

Correct Answer: D

End users are trained in the implementation phase.

Option Analysis

- **A - Incorrect:** Development is coding
- **B - Incorrect:** Disposal is retirement
- **C - Incorrect:** Initiation is planning
- **D - Correct:** Implementation includes training

Q76: SDLC Training

Question

A new customer relationship management (CRM) system is ready for deployment. Before go-live, employees attend instructor-led sessions and complete training on the new business processes. During which SDLC phase is this activity MOST likely occurring?

- A Development
- B Disposal
- C Initiation
- D Implementation

Memory Aid

Initiation = Approve Development = Build Implementation = Deploy and Train Maintenance = Operate Disposal = Retire

Q76: Explanation

Correct Answer: D - Implementation

User training is typically performed during the implementation phase when the system is being deployed and prepared for operational use.

Option Analysis

A - Incorrect: Development Development focuses on designing, building, configuring, and testing the solution. End users are generally not trained until the system is ready for deployment. **B - Incorrect: Disposal** Disposal occurs at the end of the system's lifecycle and includes decommissioning systems, data archival, and secure destruction activities. **C - Incorrect: Initiation** Initiation includes feasibility analysis, budgeting, business-case development, and project approval. User training is not normally conducted during this phase. **D - Correct: Implementation** Implementation includes deployment, data migration, user acceptance activities, end-user training, and transition to production operations.

Q77: SDLC Final Stage

Question

Which is the final stage of the SDLC?

- A Development
- B Disposal
- C Initiation
- D Maintenance

Q77: Explanation

Correct Answer: B

Disposal is the final phase of the SDLC.

Option Analysis

- **A - Incorrect:** Development is early phase
- **B - Correct:** Disposal is final phase
- **C - Incorrect:** Initiation is first phase
- **D - Incorrect:** Maintenance is ongoing

Q78: Project Risk vs SDLC Risk

Question

Key difference between project risk and SDLC risk is:

A. Project risk relates to objectives, SDLC relates to time
B. Project risk relates to objectives, SDLC relates to development
C. Project risk relates to development, SDLC relates to objectives
D. There is no difference

Q78: Explanation

Correct Answer: B

Project risk relates to project objectives; SDLC risk relates to development objectives.

Option Analysis

- **A - Incorrect:** SDLC risk is not just time
- **B - Correct:** Different focuses
- **C - Incorrect:** Reversed relationship
- **D - Incorrect:** They are different

Q78: Project Risk vs. SDLC Risk

Question

What is the PRIMARY difference between project risk and SDLC risk?

- (A) Project risk affects project objectives, while SDLC risk affects the system being developed.
- (B) Project risk affects system security, while SDLC risk affects project budget.
- (C) Project risk occurs only during implementation, while SDLC risk occurs only during development.
- (D) There is no difference between project risk and SDLC risk.

Q78: Explanation

Correct Answer: A

Project risk focuses on the successful completion of the project, while SDLC risk focuses on risks associated with the system, application, or solution being developed.

Option Analysis

A - **Correct** Project risks threaten project objectives such as schedule, budget, resources, or scope. SDLC risks relate to weaknesses in the resulting solution, such as security vulnerabilities, availability concerns, or design flaws. **B** - **Incorrect** This reverses the concepts. Security risks are generally SDLC risks, while budget risks are typically project risks. **C** - **Incorrect** Both project risks and SDLC risks may exist throughout multiple phases of the project lifecycle. **D** - **Incorrect** While related, they have different objectives and require different management approaches.

Q79: Certification Requirement

Question

Which is a must to achieve certification?

- A. A risk manager
- B. An internal audit team
- C. Policies
- D. An external audit firm

Q79: Explanation

Correct Answer: D

An external audit firm is required to certify a product.

Option Analysis

- **A - Incorrect:** Risk manager may not be required
- **B - Incorrect:** Internal audit cannot certify externally
- **C - Incorrect:** Policies alone don't certify
- **D - Correct:** External audit firm is required

Q82: Encryption Keys

Question

Which keys are required for asymmetric key encryption?

A. Only public key
B. Only private key
C. Any public or private key
D. Public and private key pair

Q82: Explanation

Correct Answer: D

Asymmetric encryption requires both a public key and a private key.

Option Analysis

- **A - Incorrect:** Public key alone insufficient
- **B - Incorrect:** Private key alone insufficient
- **C - Incorrect:** Need both keys
- **D - Correct:** Both keys are required

Q83: Symmetric Encryption

Question

Which key is required for symmetric key encryption?

- A Public and private key
- B A single key for encryption and decryption
- C Only public key and hash
- D Only private key and hash

Q83: Explanation

Correct Answer: B

Symmetric encryption uses a single key for both encryption and decryption.

Option Analysis

- **A - Incorrect:** That's asymmetric
- **B - Correct:** Single key for both
- **C - Incorrect:** Public key is asymmetric
- **D - Incorrect:** Private key is asymmetric

Q84: Integrity Definition

Question

Integrity of information means that:

A. Information is available to authorized users only
B. Information is available at all times
C. Information has not been tampered with
D. All of these

Q84: Explanation

Correct Answer: C

Integrity means information has not been tampered with.

Option Analysis

- **A - Incorrect:** That's confidentiality
- **B - Incorrect:** That's availability
- **C - Correct:** Integrity is no tampering
- **D - Incorrect:** Only C is correct

Q85: Confidentiality Definition

Question

Confidentiality of information means that:

A. Information is available to authorized users only
B. Information is available at all times
C. Information has not been tampered with
D. All of these

Q85: Explanation

Correct Answer: A

Confidentiality means information is available to authorized users only.

Option Analysis

- **A - Correct:** Confidentiality limits access
- **B - Incorrect:** That's availability
- **C - Incorrect:** That's integrity
- **D - Incorrect:** Only A is correct

Q86: Availability Definition

Question

Availability of information means that:

A. Information is available to authorized users only
B. Information is available at all times to authorized users
C. Information has not been tampered with
D. All of these

Q86: Explanation

Correct Answer: B

Availability means information is accessible when needed by authorized users.

Option Analysis

- **A - Incorrect:** That's confidentiality
- **B - Correct:** Availability is timely access
- **C - Incorrect:** That's integrity
- **D - Incorrect:** Only B is correct

Q87: Accountability

Question

Which access control principle speaks to logging and monitoring of user activities?

- A Identification
- B Authentication
- C Authorization
- D Accountability

Q87: Explanation

Correct Answer: D

Accountability deals with logging and monitoring of user activities.

Option Analysis

- **A - Incorrect:** Identification is unique ID
- **B - Incorrect:** Authentication is verification
- **C - Incorrect:** Authorization is permissions
- **D - Correct:** Accountability is logging/monitoring

Q87: Access Control Principles

Question

A security investigator needs to determine which employee accessed sensitive customer records, what actions were performed, and when those actions occurred. Which access control principle BEST supports this requirement?

- A Identification
- B Authentication
- C Authorization
- D Accountability

Q87: Explanation

Correct Answer: D - Accountability

Accountability ensures user actions can be traced to a specific individual through logging, monitoring, audit trails, and activity reviews.

Option Analysis

A - Incorrect: Identification Identification occurs when a user claims an identity, such as entering a user ID or email address. It answers the question: "Who are you?" Identification alone does not prove the user is actually that person. **B - Incorrect:**

Authentication Authentication verifies the claimed identity through passwords, MFA, biometrics, or certificates. It answers the question: "Can you prove who you are?" Authentication does not determine what the user can do after login. **C - Incorrect:**

Authorization Authorization determines which resources and actions a user is permitted to access. It answers the question: "What are you allowed to do?" It governs permissions rather than monitoring activity. **D - Correct: Accountability** Accountability requires logging and monitoring so actions can be traced back to a specific user. It answers the question: "Who performed the action?" This principle supports investigations, audits, and nonrepudiation.

Q88: Identification

Question

Which access control principle requires each user to have a separate unique name?

A. Identification
B. Authentication
C. Authorization
D. Accountability

Q88: Explanation

Correct Answer: A

Identification requires all users to have a unique ID.

Option Analysis

- **A - Correct:** Identification requires unique ID
- **B - Incorrect:** Authentication verifies identity
- **C - Incorrect:** Authorization sets permissions
- **D - Incorrect:** Accountability logs activity

Q89: Segregation of Duties

Question

SOD principle ensures that:

A. All admin access to a single user
B. Access to approve transactions is distributed
C. Confidentiality is maintained
D. Identification is in place

Q89: Explanation

Correct Answer: B

SOD ensures no single user has sole access to approve transactions.

Option Analysis

- **A - Incorrect:** SOD prevents single control
- **B - Correct:** SOD distributes authority
- **C - Incorrect:** Confidentiality is separate
- **D - Incorrect:** Identification is separate

Q90: Hashing Characteristics

Question

Which is true about hashing?

A. Provides unique output for each input
B. Is non-reversible
C. Helps maintain integrity
D. All of these

Q90: Explanation

Correct Answer: D

All options are true for hashing - unique output, non-reversible, and integrity.

Option Analysis

- **A - True:** Unique output
- **B - True:** Non-reversible
- **C - True:** Integrity verification
- **D - Correct:** All are true

Q90: Hashing

Question

Which statement BEST describes the primary purpose of hashing?

- A To provide confidentiality of data
- B To verify data integrity
- C To provide authorization
- D To facilitate key exchange

Memory Aid

Encryption = Confidentiality Hashing = Integrity Digital Signatures = Integrity + Nonrepudiation Access Controls = Authorization

Q90: Explanation

Correct Answer: B - Verify Data Integrity

Hashing generates a fixed-length value that can be used to determine whether data has been altered. If the hash changes, the data has changed.

Option Analysis

A - Incorrect: Confidentiality is primarily provided by encryption. Hashing is not designed to allow recovery of the original data and therefore is not used for protecting information in transit or storage. **B - Correct:** Hashing is commonly used to verify integrity. Matching hash values indicate that data has likely not been modified. **C - Incorrect:** Authorization determines what actions a user is permitted to perform after authentication. **D - Incorrect:** Key exchange is performed using cryptographic key-management mechanisms rather than hashing.

Q91: Digital Signatures

Question

Which is NOT provided by digital signatures?

A. Integrity
B. Non-repudiation
C. Authenticity
D. Confidentiality

Q91: Explanation

Correct Answer: D

Digital signatures do NOT provide confidentiality on their own.

Option Analysis

- **A - Incorrect:** Integrity is provided
- **B - Incorrect:** Non-repudiation is provided
- **C - Incorrect:** Authenticity is provided
- **D - Correct:** Confidentiality is not provided

Q92: Encryption and Confidentiality

Question

Sender wants only receiver to decrypt data. Which should sender use?

A. Receiver's public key
B. Sender's public key
C. Receiver's private key
D. Sender's private key

Q92: Explanation

Correct Answer: A

Use receiver's public key to encrypt so only receiver can decrypt with their private key.

Option Analysis

- **A - Correct:** Receiver's public key ensures only receiver decrypts
- **B - Incorrect:** Anyone with sender's public key
- **C - Incorrect:** Receiver's private key is not shared
- **D - Incorrect:** Sender's private key would allow anyone

Q93: Signed and Encrypted

Question

Which cryptographic mechanism provides confidentiality, integrity, and non-repudiation?

A. Signed, not encrypted
B. Encrypted, not signed
C. Signed, encrypted
D. Signed, hashed

Q93: Explanation

Correct Answer: C

Signed and encrypted provides confidentiality, integrity, and non-repudiation.

Option Analysis

- **A - Incorrect:** No confidentiality
- **B - Incorrect:** No integrity/non-repudiation
- **C - Correct:** All three provided
- **D - Incorrect:** No confidentiality

Q93: Information Protection

Question

A customer submits sensitive information through an online portal. Management requires that unauthorized parties cannot read the data, that any modification can be detected, and that the sender cannot later deny submitting the information. Which cryptographic approach BEST satisfies these requirements?

- A Digitally signed but not encrypted
- B Encrypted but not digitally signed
- C Digitally signed and encrypted
- D Digitally signed and hashed

Memory Aid

Encryption = Confidentiality Hashing = Integrity Digital Signature = Integrity + Authentication + Nonrepudiation Signed + Encrypted = All of the Above

Q93: Explanation

Correct Answer: C - Digitally Signed and Encrypted

Encryption provides confidentiality, while a digital signature provides integrity, authenticity, and nonrepudiation. Together, they satisfy all requirements in the scenario.

Option Analysis

A - Incorrect: Digitally Signed but Not Encrypted A digital signature helps verify the sender's identity and confirms that the message has not been altered. However, anyone who intercepts the message can still read its contents. Confidentiality is missing. **B - Incorrect: Encrypted but Not Digitally Signed** Encryption protects confidentiality by preventing unauthorized disclosure. However, it does not provide nonrepudiation and does not prove who originated the message. **C - Correct: Digitally Signed and Encrypted** Encryption protects confidentiality. The digital signature provides integrity, authenticity, and nonrepudiation. This combination delivers all security objectives listed in the question. **D - Incorrect: Digitally Signed and Hashed** Digital signatures rely on hashing internally and provide integrity and nonrepudiation. However, hashing does not provide confidentiality because the underlying information remains readable.

Q94: PKI SPOF

Question

Which could be a SPOF in the PKI ecosystem?

A. Certificate
B. CA
C. Requester
D. Browser

Q94: Explanation

Correct Answer: B

CA could be a SPOF if its private key is compromised.

Option Analysis

- **A - Incorrect:** Individual certificate isn't SPOF
- **B - Correct:** CA compromise affects all
- **C - Incorrect:** Requester isn't SPOF
- **D - Incorrect:** Browser isn't SPOF

Q94: PKI Trust Infrastructure

Question

An organization discovers that the private key of its root Certificate Authority (CA) has been compromised. Security leadership determines that certificates issued throughout the environment can no longer be trusted. Which PKI component represents the MOST significant single point of failure (SPOF) in this scenario?

- A Certificate
- B Certificate Authority (CA)
- C Certificate Requester
- D Browser

CRISC Memory Aid

Certificate = Identity CA = Trust Browser = Consumes Trust If the CA fails, trust in the PKI can fail.

Q94: Explanation

Correct Answer: B - Certificate Authority (CA)

The CA serves as the trust anchor of the PKI ecosystem. If the CA or its private key is compromised, confidence in certificates issued by that CA may be lost, affecting a large portion of the trust infrastructure.

Option Analysis

A - Incorrect: Certificate An individual certificate affects only the specific user, server, or application to which it was issued. Compromise of a single certificate is significant but does not generally undermine the entire PKI environment. **B - Correct: Certificate Authority (CA)** The CA validates identities and issues certificates trusted throughout the environment. Because trust originates from the CA, compromise of the CA can invalidate confidence in numerous certificates and disrupt authentication, encryption, and digital-signature processes. **C - Incorrect: Certificate Requester** The requester initiates the certificate issuance process but does not establish trust for other entities. A compromised requester affects a limited set of certificates rather than the entire PKI hierarchy. **D - Incorrect: Browser** Browsers rely on trusted certificates but are not the source of trust within the PKI ecosystem. A browser issue affects individual users, whereas CA compromise can affect all parties relying on the PKI.

Q95: Security Awareness Primary Goal

Question

Most important aspect of security awareness training is:

A. Train on latest threats
B. Show compliance with audits
C. Create security-conscious culture
D. Upskill employees

Q95: Explanation

Correct Answer: C

Most important goal is to create a security-conscious culture.

Option Analysis

- **A - Incorrect:** Latest threats change
- **B - Incorrect:** Compliance is secondary
- **C - Correct:** Culture is primary
- **D - Incorrect:** Upskilling is secondary

Q97: Data Security vs Privacy

Question

Which statement is true about data security and data privacy?

- A They are the same thing
- B Security is protecting data; privacy is protecting personal information
- C Privacy is protecting data; security is protecting personal information
- D Not important for organizations

Q97: Explanation

Correct Answer: B

Data security protects data from unauthorized access; data privacy protects personal information from misuse.

Option Analysis

- **A - Incorrect:** They are different
- **B - Correct:** Security vs privacy distinction
- **C - Incorrect:** Reversed
- **D - Incorrect:** Both are important

Q97: Data Security vs Privacy

Question

A bank encrypts customer records, restricts access based on job responsibilities, and monitors unauthorized access attempts. However, regulators determine the bank is collecting more personal information than necessary for its stated business purpose. What does this situation BEST demonstrate?

- A Data security and data privacy are the same concept
- B Strong data security does not necessarily guarantee data privacy
- C Data privacy is more important than data security
- D Data security applies only to personal information

Memory Aid

Security = Protect the Data Privacy = Use the Data Properly You can have Security without Privacy. You cannot have Privacy without Security.

Q97: Explanation

Correct Answer: B - Strong Data Security Does Not Necessarily Guarantee Data Privacy

Security and privacy are related but distinct concepts. An organization may effectively protect information from unauthorized access while still violating privacy principles through excessive collection, inappropriate use, or improper sharing of personal information.

Option Analysis

A - **Incorrect** Data security focuses on protecting information through controls such as encryption, access management, monitoring, and incident response. Data privacy focuses on the appropriate collection, use, sharing, retention, and disposal of personal information. **B** - **Correct** The organization has implemented strong security controls, yet it may still have a privacy issue because it is collecting more personal information than necessary. This illustrates that security supports privacy but does not guarantee it. **C** - **Incorrect** Both security and privacy are important and complementary. Effective governance programs must address both. **D** - **Incorrect** Security protects all forms of information, including intellectual property, financial records, operational data, and personal information. Privacy primarily focuses on personal information.

Q98: Privacy Compliance

Question

Company collecting customer data for marketing. Which measure ensures compliance with privacy regulations?

A. Use encryption
B. Obtain consent
C. Implement firewalls
D. Train employees

Q98: Explanation

Correct Answer: B

Obtaining consent is critical for compliance with GDPR, CCPA, and other privacy regulations.

Option Analysis

- **A - Incorrect:** Encryption is security, not privacy
- **B - Correct:** Consent is required
- **C - Incorrect:** Firewalls are security
- **D - Incorrect:** Training is important but not primary

Q98: Privacy Compliance

Question

An organization plans to use customer information collected through its website to support targeted marketing campaigns. Before the information is used, management wants to reduce the risk of privacy compliance violations. Which action is MOST important?

- A Encrypt the customer database
- B Obtain appropriate customer consent
- C Deploy additional firewall controls
- D Conduct security awareness training

CRISC Memory Aid

Security asks: "How do we protect the data?" Privacy asks: "Do we have the right to collect and use the data?" Consent = Privacy
Encryption/Firewalls = Security

Q98: Explanation

Correct Answer: B - Obtain Appropriate Customer Consent

Privacy regulations generally require organizations to have a lawful basis for collecting and processing personal information. Obtaining appropriate consent is often a key requirement when personal information is used for marketing purposes.

Option Analysis

A - Incorrect: Encrypt the Customer Database Encryption helps protect the confidentiality of customer information and reduces security risk. However, strong security controls alone do not provide authorization to collect or use personal information for marketing purposes. **B - Correct: Obtain Appropriate Customer**

Consent Consent helps ensure that customers understand how their information will be used. From a privacy perspective, this is generally more important than technical controls when the issue involves the lawful use of personal information. **C - Incorrect:**

Deploy Additional Firewall Controls Firewalls help protect systems from unauthorized access and cyberattacks. They support security objectives but do not address whether the organization has permission to process personal data. **D - Incorrect: Conduct**

Security Awareness Training Training helps employees understand privacy and security responsibilities. While valuable, it does not by itself establish a legal basis for collecting

Q99: Vulnerability Management KPI

Question

Which KPI is most appropriate to measure vulnerability management program effectiveness?

A. Number of vulnerabilities found and remediated

B. Number of security incidents reported

C. Percentage of employees trained

D. Average incident response time

Q99: Explanation

Correct Answer: A

Number of vulnerabilities found and remediated measures vulnerability management effectiveness.

Option Analysis

- **A - Correct:** Direct measure of VM program
- **B - Incorrect:** Measures incident response
- **C - Incorrect:** Measures training program
- **D - Incorrect:** Measures IR effectiveness

Q100: Security Program KPI

Question

Which KPI is most useful to evaluate security program effectiveness over time?

- A Number of employees trained
- B Number of security incidents reported
- C Average detection and response time
- D Percentage reduction in data breaches

Q100: Explanation

Correct Answer: D

Percentage reduction in data breaches directly measures program impact over time.

Option Analysis

- **A - Incorrect:** Training completion not a direct measure
- **B - Incorrect:** Incidents may change
- **C - Incorrect:** Response time is operational
- **D - Correct:** Direct measure of program success

Q100: Security Program Performance

Question

Senior management wants to evaluate whether the organization's security program is becoming more effective at identifying and responding to security incidents. Which KPI would provide the MOST useful measurement?

A. Number of employees completing security awareness training
B. Number of security incidents reported
C. Average detection and response time
D. Number of audit findings

Q100: Explanation

Correct Answer: C - Average Detection and Response Time

Effective security programs should improve the organization's ability to detect and respond to threats quickly. Measuring detection and response time provides a direct indication of operational security effectiveness and can be tracked over time.

Option Analysis

A - Incorrect: Number of Employees Completing Security Awareness Training
Training completion measures participation in a security initiative rather than the effectiveness of the security program itself. Employees may complete training while security performance remains unchanged.

B - Incorrect: Number of Security Incidents Reported
A higher number of reported incidents may indicate either worsening security or improved detection and reporting. The metric alone does not reliably measure effectiveness.

C - Correct: Average Detection and Response Time
Faster detection and containment reduce organizational exposure and financial impact. Improvements in this KPI typically indicate stronger security operations.

D - Incorrect: Number of Audit Findings
Audit findings identify control weaknesses but may vary based on audit scope, timing, and methodology. They are not a direct measure of day-to-day security performance.

CRISC Key Takeaways

Essential Concepts

- Governance provides oversight and direction from Board
- Risk identification is the first step - "You can't protect what you don't know"
- Risk Appetite = willingness to accept risk
- Risk Tolerance = acceptable variation from appetite
- Risk Capacity = maximum risk before existence threatened
- RPO is backward-looking; RTO is forward-looking

CRISC Key Takeaways (continued)

More Essential Concepts

- 3LoD: First = Operations, Second = Oversight, Third = Audit
- Residual Risk = Inherent Risk - Controls
- Risk Response: Mitigate, Accept, Transfer, Avoid
- SMART: Specific, Measurable, Attainable, Relevant, Timely
- CIA: Confidentiality, Integrity, Availability
- Digital signatures: Integrity, Non-repudiation, Authenticity (NOT confidentiality)

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each concept
- Know control categories and their differences
- Understand recovery objectives (RPO, RTO, MTD)
- Know risk appetite vs tolerance vs capacity
- Practice scenario-based questions

Good Luck on Your CRISC Exam!

CRISC Memory Sheet: Risk Terms

Risk Fundamentals

RA = Risk Assessment
BIA = Business Impact Analysis
ERM = Enterprise Risk Management
KRIs = Key Risk Indicators
KPIs = Key Performance Indicators
KCIs = Key Control Indicators

Inherent Risk = Risk before controls.
Residual Risk = Risk after controls.
Control Gap = Missing or ineffective control.

Risk Appetite = Desired risk.
Risk Tolerance = Acceptable variation.
Risk Capacity = Maximum survivable risk.

CRISC Memory Sheet: BIA

Business Impact Analysis (BIA)

BIA Outputs:
RTO = Recovery Time Objective
RPO = Recovery Point Objective
MTD = Maximum Tolerable Downtime
MAO = Maximum Acceptable Outage

RPO = Data Loss
RTO = Recovery Time
MTD = Business Survival Limit

Rule:
RTO $\leq$ MTD

BIA determines:
Critical Processes
Dependencies
Business Impact
Recovery Priorities

CRISC Memory Sheet: Controls

Control Types

Preventive = Stop
Detective = Detect
Corrective = Recover
Deterrent = Discourage
Compensating = Alternate
Directive = Guide
Recovery = Restore

MFA = Preventive
Firewall = Preventive
SIEM = Detective
IDS = Detective
Backup Restore = Corrective
Security Banner = Deterrent

CRISC Memory Sheet: Access Control

IAAA Model

Identification
= Who are you?

Authentication
= Prove it.

Authorization
= What can you do?

Accountability
= What did you do?

Logging + Monitoring
= Accountability

CRISC Memory Sheet: Cryptography

Crypto Fundamentals

PKI = Public Key Infrastructure
CA = Certificate Authority
CRL = Certificate Revocation List
CSR = Certificate Signing Request

Encryption
= Confidentiality
Hashing
= Integrity
Digital Signature
= Integrity + Authenticity + Nonrepudiation

Signed + Encrypted
= Confidentiality + Integrity + Nonrepudiation

CRISC Memory Sheet: Vendor Governance

Third-Party Management

MSA = Master Service Agreement
SLA = Service Level Agreement
NDA = Non-Disclosure Agreement
SOC = System and Organization Controls Report

MSA = Relationship
SLA = Performance
NDA = Confidentiality
SOC = Assurance

Service Credits?
= SLA

CRISC Memory Sheet: SDLC

System Development Life Cycle

Initiation
= Budget + Approval

Development
= Build + Test

Implementation
= Deploy + Train

Maintenance
= Operate + Patch

Disposal
= Retire + Destroy

CRISC Memory Sheet: CMM

Capability Maturity Model

Level 1 = Initial
(Ad Hoc)

Level 2 = Repeatable

Level 3 = Defined

Level 4 = Managed
(Measured)

Level 5 = Optimized
(Continuous Improvement)

CRISC Memory Sheet: Privacy

Privacy and Security

PII = Personally Identifiable Information
PHI = Protected Health Information
DLP = Data Loss Prevention

Security
= Protect Data

Privacy
= Proper Use of Data

Consent
= Privacy

Encryption
= Security

Ultimate CRISC 30-Second Dump

High-Yield Facts

BIA → RTO, RPO, MTD
RA → Threats, Vulnerabilities
KPI → Performance
KRI → Risk
KCI → Controls

Preventive = Stop
Detective = Detect
Corrective = Fix

Accept = Keep
Mitigate = Control
Transfer = Insurance
Avoid = Stop Activity

Encryption = Confidentiality
Hashing = Integrity
Signature = Nonrepudiation